从零开始理解 BiT-128 攻击

——写给只了解皮毛的同学的完整知识脉络（v2，含 9-28 更正）

GLM-5.3 Flash max　　Jy L

配套《BiT-128 签名方案的公开数据统计攻击》技术报告使用

2026 年 9 月

这份文档怎么读

读者假设：你会模运算（$17 \equiv 4 \pmod{13}$ 这种）、知道哈希函数是” 单向压碎机”、知道公钥私钥的大概概念。除此之外**不需要**任何格密码、拒绝采样或 NGCC 的背景——所有需要的东西都在这里从头建立。

结构：第 1–4 章打地基（数学工具、签名骨架、拒绝采样、BiT 流程）；第 5–9 章是攻击本身（每章回答一个问题）；第 10 章是实验时间线；第 11 章是交叉验证；第 12 章是 FAQ。第 13 章有符号速查表。

配套：严谨版是同目录的 `BiT128_attack_report.pdf`（技术报告）；演讲版是 `BiT128_seminar_beamers.pdf`（讨论班）。

目录

1 数学地基：环与” 会环绕的多项式” **2**

1.1 模运算：一根 26881 刻度的圆尺 2

1.2 多项式：256 个数字排成一列，乘法会” 环绕” 2

1.3 ” 小乘小、加起来不大” 2

2 数字签名的骨架与 Fiat–Shamir **2**

2.1 签名要证明什么 2

2.2 Fiat–Shamir：把” 问答” 压成” 独白” 3

2.3 拒绝采样：为什么” 扔了重扔” 3

3 双峰技巧与共享符号位 **3**

3.1 双峰：掩码减半的代价 3

3.2 这个比特就是猎物 3

4 BiT-128 签名全流程（带直觉重走） **3**

4.1 三份掩码，三种用途 3

4.2 挑战从哪来：承诺再提问 4

4.3 三个拒绝阶段 4

4.4 hint：给验证器的小抄 4
4.5 一条代数金线 4

5 缺口在哪里：边缘独立 $\neq$ 联合独立 4
5.1 玩具模型 4
5.2 BiT 的具体情况 4

6 通道一：z_0——先偷到那个比特 4

7 通道二：hint——y_2 的精确抵消 5
7.1 第一步：写出 h 的量测对象 5
7.2 第二步：展开差值，y_2 消失 5
7.3 第三步：读出模型 5
7.4 第四步：对齐累加 5

8 场定律：剩下那个” 洗不掉” 的东西 6
8.1 意外：直接累加失败 6
8.2 配方：ε-对齐会消去 ε，也会” 晒出” 卷积的形状 6
8.3 传播到 Φ：tent 核 6

9 从 R 到等价私钥 6
9.1 算子求逆 + 逐行标度 6
9.2 mod-q 线性求解 6
9.3 nbad razor：一把锋利的判刀 6
9.4 等价私钥 7

10 实验时间线：每一步回答了什么问题 7

11 交叉验证：凭什么信 7

12 常见问题（室友友好版 FAQ） 8

13 符号速查表 9

1 数学地基：环与”会环绕的多项式”

1.1 模运算：一根 26881 刻度的圆尺

$\mathbb{Z}_q$ 就是”把所有整数按 $q = 26881$ 收卷成一个圆”：$17 \equiv 17$，$26881 \equiv 0$，$53695 \equiv -67$。习惯上每个数用它在 $[-q/2, q/2)$ 里的 **中心代表** $\mathrm{center}(x)$ 表示。-1 和 $q-1$ 是同一个东西的两件外衣。

直觉

把 $\mathbb{Z}_q$ 想成一根 26881 刻度的圆尺弯成一个环。”加一个大数”等于在环上转了很多圈又回到附近；”模 q”就是只记你最终停在哪一刻度。

1.2 多项式：256 个数字排成一列，乘法会”环绕”

格密码对**系数很小的多项式**做运算：$f(x) = f_0 + f_1 x + \cdots + f_{255} x^{255}$，$f_i \in \mathbb{Z}_q$。乘法规定 $x^{256} \equiv -1$：最高次项乘上去会**翻个符号绕回常数项**——负循环（negacyclic）。

直觉小例子：$d = 4$

$(a_0 + a_1 x + a_2 x^2 + a_3 x^3) \cdot (b_0 + b_1 x)$ 的普通乘积里有一项 $a_3 b_1 x^4$；因为 $x^4 \equiv -1$，它变成 $-a_3 b_1$ 加回常数项。一般地：

$$(f * g)[j] = \sum_k f[k]\, g[(j-k) \bmod d] \cdot (-1)^{\mathbf{1}[j<k]},$$

”下标绕回去时配一个负号”。这个负号因子是双刃剑：它让环代数成立，也让攻击里的对齐统计要小心符号——第 7 章反复用到。

检查点

$d = 4$ 时计算 $(1 + x) * (1 - x)$。答案：$1 - x^2$。再乘 x^2 呢？$-1 + x^2$ ——x^2 项翻了符号（$x^4 \equiv -1$）。

1.3 ”小乘小、加起来不大”

BiT 所有秘密量都很小：s_0, e 系数在 $\{-1, 0, 1\}$；掩码 y 系数在 ± 2047 内。30 项 ± 1 相加落在 $[-30, 30]$。**”小秘密卷上已知的小东西，得到的还是（相对）小的、分布可计算的量”**——全文反复出现的主题。

2 数字签名的骨架与 Fiat–Shamir

2.1 签名要证明什么

数字签名：持有私钥的人能对任意消息 m 产生凭证 σ，任何人可验证，但看过再多签名也**造不出**新消息的签名（EUF-CMA）。格签名是零知识证明的变体：证明”我知道一个很短的 s_0 满足 $A_0 s_0 \equiv$ 某公开值”，但不泄露 s_0。

2.2 Fiat–Shamir：把”问答”压成”独白”

原始零知识证明是对话：证明者扔掩码 y、给承诺 w；验证者随机出题 c；证明者回答 $z = y + (\text{含} s_0 \text{ 的项})$。因为 y 均匀，z 看起来均匀。**Fiat–Shamir** 把考题换成 $\tilde{c} = H(\text{消息} \| w)$——哈希充当”懒惰但公正的考官”。BiT 正是这样。

2.3 拒绝采样：为什么”扔了重扔”

$z = y + \varepsilon(s_0 * c)$ 里混着秘密项，z 的分布会向 $\pm s_0 * c$ 偏一点——统计足够多 z 就能恢复秘密。补救：**算完检查，不像标准分布就整个扔掉重来**。发布后的 z 都来自标准分布。

容易想错的地方

拒绝采样堵的是”z 的**边缘分布**失真”。它**不**保证”z 与扔硬币结果的**联合**分布无关”。BiT 的缺口正在后者——第 5 章。

3 双峰技巧与共享符号位

3.1 双峰：掩码减半的代价

掩码要够宽才能盖住秘密项。双峰观察：挑战可整体乘 ± 1 时，响应的两个候选分布对称——掩码可**减半**。签名时掷一个比特 b，$\varepsilon = (-1)^b$，$c_{\text{signed}} = \varepsilon c_{\text{can}}$——**整条签名共享同一个** ε。

3.2 这个比特就是猎物

两个事实：(1) ε 是**一个**比特，但影响整条签名的**所有**分量（z_0, z_1, z_2, h 全含其符号）；(2) 规范 §3.1.3 声称”z 与 b 独立”——按字面理解攻击者无法知道 b。第 5 章会看到：每个分量**单独**看或许独立，合起来不是。

4 BiT-128 签名全流程（带直觉重走）

参数：$d = 256$，$q = 26881$，$\tau = 30$，$\gamma_2 = 682$，$K = L = 3$。秘密 $s_0 \in \{-1, 0, 1\}^{3\times 256}$，$e$ 同型；$b = A_0 s_0 + e = 16b_1 + b_0$ （b_1 公开、$b_0 \in [-8, 8)$ 保密）。

4.1 三份掩码，三种用途

掩码	宽度	参与的响应	秘密搭档
y_0	± 7（3-bit 三角）	$z_0 = y_0 + c_{\text{signed}}$	无（c 是公开形状）
y_1	± 1023（10-bit）	$z_1 = y_1 + s_0 * c_{\text{signed}}$	s_0
y_2	± 2047（11-bit）	$z_2 = y_2 + e * c_{\text{signed}}$	e

z_0 特殊：秘密部分只是 $\pm c_{\text{can}}$ 形状的公开挑战，掩码可极窄。

4.2 挑战从哪来：承诺再提问

每轮：$w = A_0 y_1 - 16 b_1 y_0 + \hat{q} y_0$（行 0）$+ y_2$，其高位摘要进哈希：$\tilde{c} = H(\mu \| w_1)$，展开出挑战 c_{can}（30 个 $+1$）。**掩码先承诺，挑战后到**。

4.3 三个拒绝阶段

(1) z_0, z_1 检查（失败只重扔 y_0, y_1）；(2) z_2 检查（失败全扔）；(3) hint 与范数检查（失败全扔）。注意：**”接受”本身是以秘密为条件的事件**。

4.4 hint：给验证器的小抄

验证器重算 w'，想知道原来的高位 w_1；但 w' 与签名时的 w 差一点，高位可能差一两格。h 就是**纠错小抄**：告诉验证器每坐标的格子号怎么调。调完哈希对上，验证通过。

4.5 一条代数金线

密钥生成保证

$$A_0 s_0 \equiv 16 b_1 + (b_0 - e) \pmod{q}, \qquad R := b_0 - e \in [-9, 8]^{3 \times 256}. \tag{1}$$

R 公钥可计算；反过来知道 R 也能解出 s_0（第 9 章）。R **是连接公开世界与秘密世界的桥**——攻击目标从”恢复 s_0”等价变成”恢复 R”。

5 缺口在哪里：边缘独立 $\neq$ 联合独立

5.1 玩具模型

两个坐标的玩具签名：拒绝规则说”$|z|$ 太大就扔”。**被发布**的签名里两坐标的联合分布与理想模型不同——每坐标边缘可能合规，但**相关性**泄露秘密。

直觉

海关只检查每件行李是否超标；但”行李超标的旅客往往有同伙”——联合检查（看相关性）能发现走私网络。拒绝采样是海关，联合分布是走私网络。

5.2 BiT 的具体情况

规范 §3.1.3 声称独立。而联合响应实际保留秘密相关的跨坐标相关——我们自己的实验从数据上证实并精确刻画（第 7 章）：同键双数据集的统计量零位置模式相关达 0.9907——确定性的、随 N 增长的指纹。

6 通道一：z_0——先偷到那个比特

支撑位置上 $z_0 = y_0 \pm 1$：$\varepsilon = +1$ 发布值集中在 $[-6, 7]$（右截断），$\varepsilon = -1$ 集中在 $[-7, 6]$（左截断）。不对称 $\Rightarrow$ 逐位置对数似然比 $\ln[f_0(z-1)/f_0(z+1)]$ 求和得 Λ，$\hat{\varepsilon} = \text{sign}(\Lambda)$。$10^6$ 真实签

名实测 96.19%（边界事件覆盖 62.3%、逐事件 100%）。**攻击者现在知道每条签名的 ε（96.2% 置信）**。

关于 z_1 通道：它携带 s_0 的一阶信息。我们早期用压缩统计量 $\psi(z) = \mathrm{sign}(z)/(1024 - |z|)$ 加简单阈值估计它时观察到不收敛，于是转向 hint 通道。【2026-09-28 更正】不收敛是那个压缩统计量与阈值判决的缺陷——z_1 通道用正确的加权回归是收敛的（我们后来完整复现了这条路线，两种路线恢复出**同一把**等价私钥）。hint 通道的价值在于：它给出 R 的**直接**一阶观测、确定性结构可写成精确公式并求逆。

7 通道二：hint——y_2 的精确抵消

7.1 第一步：写出 h 的量测对象

$h[j] = \mathrm{fold}_{40}(\mathrm{cell}(w[j]) - \mathrm{cell}(w_a[j]))$，cell 把环切成 40 格（格宽 $\gamma_2 = 682$），$w_a[j] = w[j] - z_2[j] + (b_0 * c_{\mathrm{signed}})[j]$（行 0 且 $b = 0$ 时再加 $c_{\mathrm{signed}}[j]$）。

7.2 第二步：展开差值，y_2 消失

$$w[j] - w_a[j] = z_2[j] - (b_0 * c)[j] - \cdots = y_2[j] + (e * c)[j] - (b_0 * c)[j] - \cdots = y_2[j] - (R * c_{\mathrm{signed}})[j] - \cdots$$

直觉魔法的本质

w 里有 $+y_2$，z_2 里也有 $+y_2$。签名者把 z_2 **减**回去——y_2 一进一出**精确抵消**。设计者想要”hint 只依赖好处理的量”；没注意抵消之后**剩下的是** R。

7.3 第三步：读出模型

$\Delta[j] = y_2[j] - a[j]$（$a[j] = (R * c_{\mathrm{signed}})[j]$ 加行 0 项），$\mathbb{E}[h[j] | \Delta[j]] \approx \Delta[j]/\gamma_2$：$h$ 是 Δ/γ_2 的 7 级量化读数。MC 斜率 -1.4826×10^{-3} vs 理论 -1.4663×10^{-3}。

检查点

为什么 y_2 是噪声而非信号？——y_2 每条签名全新、与密钥无关；$a[j]$ 里藏着**固定的** R。平均会留下 a、洗掉 y_2。

7.4 第四步：对齐累加

$$\Phi_R[i][m] = \sum_{n,t} \hat{\varepsilon}_n \, \mathrm{flip} \cdot h_n[(m + p_{n,t}) \bmod d]$$

$\hat{\varepsilon}_n$（通道一的标签）把每条签名的信号对齐同号相加。N 条签名 $\times$ $\tau = 30$ 位置 $= N\tau$ 个一阶观测，全部指向同一个 R。

8 场定律：剩下那个” 洗不掉” 的东西

8.1 意外：直接累加失败

$N = 10^6$ 累加后直接分类失败：残差是独立噪声预期的 23–37 倍，同键另一套数据在同样位置呈同样模式（相关 0.99）。像被” 染色”——但这次**染料有精确配方**。

8.2 配方：ε-对齐会消去 ε，也会” 晒出” 卷积的形状

$h[j'] = (y_2[j'] - \varepsilon a_0[j'])/\gamma_2$，其中 $a_0[j'] = \sum_t (\pm) R[(j' - p_t)]$ 不带 ε。乘 $\hat{\varepsilon}$ 后 a_0 贡献不带 ε 地进入期望，而

$$\mathbb{E}[a_0[j]] = \frac{\tau}{d}\big(2\,\mathrm{CumR}[j] - \Sigma R\big)$$

——R 的**前缀和**（随机游走）。实测逐位置场与该式相关 0.989。

8.3 传播到 Φ：tent 核

$$\mathbb{E}[\Phi_R[i][m]] = -\frac{1}{\gamma_2}\Big[sMR_i[m] + \beta \sum_v K[m,v] R_i[v] + sP_0M(1 - \tfrac{2m}{d})\mathbf{1}[i=0]\Big],$$

$K[m,v] = d - 2|m - v|$（tent 核），$\beta = N\tau(\tau-1)/d^2$。位置互斥 Monte-Carlo 算子与解析 tent 相关 0.9911。

直觉本章的” 啊哈”

z_1 的确定性结构需要建模才能消除；hint 的结构**写得出解析式**——系数只含公开常数（$M, \beta, K, d, \gamma_2, P_0$）。**写得出解析式，就能求逆**。

9 从 R 到等价私钥

9.1 算子求逆 + 逐行标度

解 $(sM\mathbb{I} + NF_{\mathrm{op}})\hat{R}_i = -\gamma_2 \Phi_R[i] +$ 行 0 修正。s 逐行用整数聚类目标 $\frac{1}{d}\sum_m \cos(2\pi \hat{R}_i[m])$ 拟合（真值处聚于整数，目标 ≈ 0.8）。

9.2 mod-q 线性求解

$A_0 s_0 \equiv 16 b_1 + R \pmod q$：768 个方程、768 个未知数，$A_0$ 模素数可逆，解唯一精确。

9.3 nbad razor：一把锋利的判刀

s_0 错一个坐标会通过 A_0^{-1} **稠密扩散**到全部 768 坐标。$\mathrm{nbad} = \#\{j : s_0[j] \notin \{-1, 0, 1\}\}$：真修正 $\Rightarrow 0$；错误修正 $\Rightarrow \approx 768$。收尾器只接受 $\mathrm{nbad} = 0$ 的修正（教训：贪心接受”nbad 减一” 会毁掉全局）。

9.4 等价私钥

$\hat{e}_m = -\mathbf{1}[R_m \geq 8] + \mathbf{1}[R_m \leq -9]$，$\hat{b}_0 = R + \hat{e}$，则 $A_0 s_0 + \hat{e} \equiv 16 b_1 + \hat{b}_0$——$(s_0, \hat{e}, \hat{b}_0)$ 与真钥签名能力相同。实测 $\hat{e}$ 非零 26 坐标（理论预期 ≈ 32，吻合）。

10 实验时间线：每一步回答了什么问题

实验室日志第一天：基础设施与”染色”发现

阶段 A–C：公开数据管线与 C 内部值逐字节一致（$10^6/10^6$）；z_0 标签 96.19%；z_1 统计量三臂对照建立。**阶段 5**：同键双数据集 Φ 零位置模式相关 0.9907——确定性结构存在。**阶段 6/6B**：ICM 精化发散；逐坐标去场失败；场的来源定位为选择耦合。**阶段 E/F**：代数上等价私钥成立（$R = b_0 - e$ 逐系数验证）；oracle 密钥 20/20 通过原始验证器——机制通，当时误以为攻击路径未通（见下）。

实验室日志第二天：文献、hint 与闭合

上午：文献定位与代码审计——重新读 sign.c 找未被利用的公开量。**hint 审计**：发现 y_2 抵消 $\Rightarrow$ hint 是 R 的直接观测。**tier-1 验证**：MC 斜率、池化信号、逐位置场——通道真实。**累加与意外**：10^6 累加直接分类失败——决定**推导**那个结构。**场定律**：tent 算子与实测 corr 0.997。**求逆与收尾**：oracle 臂单修正闭合 $\rightarrow s_0$ 768/768；attack 臂 7 错（iid 噪声跨界）。**扩样闭合**：合并 4×10^6 签名，逐行标度，**直接零错误**，s_0 768/768；**伪造 20/20**。**交叉验证**：七项检查全部通过。

实验室日志第三天（2026-09-28）：更正与复现

我们在自己的数据与实现上**完整验证**了 z_1 加权回归路线：RMSE 0.184@20 万、直接错误 6/768、公钥修正后闭合——恢复出**同一把**等价私钥。这同时带来一个重要更正：我们此前”z_1 路线饱和、不收敛” 的判断是**错误**的（那是我们早期压缩统计量与阈值判决的缺陷，不是通道的缺陷）。z_1 回归路线成立；hint 通道是第二条独立路线——两路线互为独立见证。

11 交叉验证：凭什么信

1. 不同代码路径：FFT $[x, -x]$ 独立重算负循环积，$R = b_0 - e$ 精确。
2. 跨轮次：三份密钥文件（阶段 E / hint-oracle / hint-attack）SHA-256 一致。
3. 不同数据组合：real+sim1m（不含第三套）独立重跑——同样零错误、同一密钥。
4. 跨数据集：两套数据独立拟合的 $\hat{R}$ 一致 761/768，corr 0.999。
5. 实现无关性：累加器两种分块逐元素一致；快速版与慢速版逐元素一致。
6. 原始 C 全量复核：3×10^6 条签名全部通过未修改的原始验证器；伪造 20/20 通过、4 组阴性对照全部拒绝。

7. 第二条路线交叉验证：z_1 回归路线在同一数据上闭合，恢复同一把等价私钥。

直觉

任何单一实验都可能出错；但” 换代码、换数据、换轮次、换验证器、甚至换一条攻击路线” 之后**同一个结论反复出现**，出错的可能性就被压到很低。

12 常见问题（室友友好版 FAQ）

Q1：为什么不直接暴力枚举私钥？ s_0 有 $3^{768} \approx 10^{366}$ 种取值。可观测宇宙的原子数约 10^{80}。暴力在数学上不可行——所以才有统计攻击这种迂回打法。

Q2：等价私钥是真私钥吗？ 不是。攻击者拿到的是 $(s_0, \hat{e}, \hat{b}_0)$——满足同一条代数关系、签名能力相同、但个别坐标与真钥不同。对验证器二者不可区分——危害同级。

Q3：会不会只是统计巧合？ 恢复出的 s_0 与真钥 768/768 逐系数一致；两条独立路线恢复出同一把钥；在未修改的原始 C 签名器上 20/20 通过原始验证器，4 组对照全部拒绝。巧合无法伪造这些。

Q4：需要量子计算机吗？ 不需要。纯经典统计攻击：读签名、算直方图、解线性方程。笔记本就能跑。

Q5：修复难吗？ 方向明确：不共享符号位、加宽 z_0 掩码、重审 hint 论证式。工程量不大，但安全证明要按混合分布模型重做。

Q6：为什么叫” 双峰”？ 响应的目标分布有两个对称的峰（来自 $\pm\varepsilon$），像骆驼双峰——这也是掩码可减半的原因。

Q7：4×10^6 签名现实吗？ 签名是公开量：一个服务每秒签几千条，一两天就攒够。攻击管线单机数小时跑完。（z_1 回归路线按其报告声称 20–25 万条即可；两条路线互补。）

Q8：你们的工作和论坛上那份工作的关系？ 同一病根（共享符号位 + 联合分布泄露）、同一目标（等价私钥 + 伪造）。恢复路线不同：他们用 z_1 回归 + 置信窗口 Gray 码修正；我们用 hint 通道 + 场算子求逆 + 全解一致性 razor。我们复现了他们的路线（独立见证），他们没有我们的 hint 通道（其论文只列为未来方向）。

13 符号速查表

符号	含义
$d = 256,\ q = 26881$	维度与模数；$x^d \equiv -1$
$\tau = 30$	挑战非零系数个数（全为 $+1$）
s_0, e	主私钥与误差（短向量）
b_1（公开）/ b_0（保密）	$b = A_0 s_0 + e = 16 b_1 + b_0$ 的高/低位
$R = b_0 - e$	攻击目标（公钥可计算）
y_0, y_1, y_2	掩码（3/10/11-bit 三角）
z_0, z_1, z_2	响应 = 掩码 + 秘密卷积
$\varepsilon = (-1)^b$	共享双峰符号位
Λ	z_0 通道的对数似然比（96.2% 标签）
cell, h	γ_2-格号与 hint
$\Phi_R[i][m]$	hint 通道的对齐累加统计量
$K[m, v] = d - 2\lvert m - v\rvert$	场的 tent 核
nbad	一致性判刀

全部数字可复现：脚本、种子、产物见技术报告；

配套材料：`BiT128_attack_report.pdf`（严谨版）、`BiT128_seminar_beamers.pdf`（讨论班）。